

DISASTER RECOVERY PLAN

ShopEase Online Retail

CIS4365 – Enterprise Cybersecurity

Version	v1.0
Date	April 8, 2026
Owner	Business Continuity & DR Manager
BCP Reference	ShopEase BCP v1.0 (April 2026)
Classification	CONFIDENTIAL – Internal Use Only
Status	APPROVED – Active

Prepared by: Aykhan Pashayev Business Continuity & DR Manager | Reviewed by: Christian Acevedo, CISO

1. Document Control

Field	Details
Document Title	Disaster Recovery Plan — ShopEase Online Retail
Version	v1.0
Effective Date	April 8, 2026
Document Owner	Business Continuity & DR Manager
Executive Sponsor	Christian Acevedo, CISO
Primary Author	Mathias Benkert, SOC Lead
IT Lead	IT & Cloud Operations Manager
Compliance/Risk	Fraud Prevention & Compliance Team Lead
BCP Reference	ShopEase BCP v1.0 — this DRP is the technical restoration complement to the BCP
BIA Reference	ShopEase BIA v1.0 — RTO/RPO targets drive all recovery objectives herein
Distribution	CISO, IT & Cloud Ops, DevOps (on-call), Fraud & Compliance, Legal/Privacy Lead
Review Cadence	Annual minimum; after any DR activation, major infrastructure change, or vendor change

2. Purpose, Scope & Relationship to BCP

2.1 Purpose

The Disaster Recovery Plan (DRP) defines the technical procedures, runbooks, and validation steps required to fully restore ShopEase Online Retail's IT systems and infrastructure after a disruptive event. While the BCP keeps the business operating at a minimal viable level, this DRP governs the complete rebuild and restoration of all systems to normal operational capacity.

KEY DISTINCTION: The BCP keeps ShopEase running at 'good enough.' The DRP restores ShopEase to 'fully normal.' Both must be activated in sequence — BCP first, DRP completes the job.

2.2 Scope

In Scope:

- AWS cloud infrastructure: EC2 instances, RDS databases, WAF, CloudFront, Load Balancers, S3, IAM, SIEM
- Application stack: E-Commerce Website/API, Product Search API, Payment Processing integration, Fraud Scoring Engine, Inventory Management System
- Network layer: VPN, Cloud Firewalls, cloud routers, IDS/IPS, DNS management, CDN

- Security tooling: Cloud-native SIEM, Vulnerability Scanner, Encryption Key Management, IDS & IPS, WAF
- Data assets: Customer PII databases, order history, transaction metadata, inventory data, PCI-DSS compliance artifacts
- Endpoint recovery: DevOps workstations, warehouse terminals, administrative workstations
- Third-party integrations: Payment gateway re-integration, FedEx/UPS carrier API restore, SaaS tool reconnection

Out of Scope:

- Business process continuity during outage (covered by BCP v1.0)
- Physical facility recovery (covered by Physical Security & Facility Management plan)
- HR/payroll systems (separate recovery plan maintained by HR)

2.3 Relationship Between BCP and DRP

Dimension	BCP	DRP (This Document)
Purpose	Keep business operating at minimal viable level	Fully restore all IT systems to normal capacity
Activation	Activated first, at incident declaration	Activated after BCP stabilizes operations
Owner	Business Continuity & DR Manager	Business Continuity & DR Manager
Duration	Hours to days (until DRP complete)	Hours to days (until full restoration confirmed)
Focus	People, process, manual workarounds	Systems, data, infrastructure, integrations
Handoff	BCP passes DRP Handoff Package to DR team	DRP issues 'All Clear'; BCP deactivated

3. Recovery Objectives (RTO / RPO / RCO)

All objectives are derived from the ShopEase BIA v1.0. The DRP must demonstrate it can meet or beat every target below. Any gap must be documented as a known risk with a mitigation plan.

System / Process	Tier	RTO	RPO	RCO (Recovery Consistency)	DR Strategy	Notes / Gaps
Payment Processing	1	2h	15min	Zero unreconciled transactions	Secondary gateway pre-integrated; automatic failover	CRITICAL GAP: secondary gateway not yet contracted — Priority action item
E-Commerce Platform	1	4h	30min	No customer-visible data loss; last	AWS multi-region active-passive; RDS	Daily backup automation + point-in-time recovery

System / Process	Tier	RTO	RPO	RCO (Recovery Consistency)	DR Strategy	Notes / Gaps
(Website + API)				committed order preserved	cross-region read replica; CloudFront failover	active per case study
Inventory Management	2	24h	4h	Stock count delta < 2% variance	Manual stock sheets during outage; batch DB restore from last snapshot	Warehouse staff trained on manual fallback (BCP Runbook B)
Customer Support (VoIP + CRM)	3	24h	12h	No ticket data loss; full CRM restored	Remote email-only fallback during outage; CRM restore from cloud backup	Support team is remote-capable; continuity email pre-configured
AWS Infrastructure (IAM, SIEM, WAF)	1	2h	N/A (stateless config)	Infrastructure-as-Code validates config consistency	IaC (Terraform/CDK) stored in version-controlled repo; redeploy to secondary region	IaC must be tested quarterly; config drift is a known risk
Security Controls (WAF, IDS/IPS, SIEM, Vuln Scanner)	1	1h	N/A	Security monitoring must be restored before re-enabling public traffic	Automated redeploy via IaC; SIEM rules stored in code repo	SIEM must be verified active BEFORE customer-facing services are re-enabled
Backup Systems	1	1h	N/A	Backup integrity verified before DR declared complete	AWS S3 cross-region replication; RDS automated snapshots; daily backup to secondary region	Backup restoration must be tested annually — currently unvalidated (risk assessment finding)

Tier Legend:

Tier	Color	Definition
Tier 1 – CRITICAL	Red	Restoration failure within RTO = direct, quantifiable revenue loss (>\$40k/hr) or PCI-DSS non-compliance
Tier 2 – HIGH	Orange	Restoration failure within RTO = significant operational disruption and contract/SLA violations
Tier 3 – MEDIUM	Green	Restoration failure within RTO = customer satisfaction impact; no immediate revenue or compliance impact

4. DR Team Roles & Responsibilities

Role	Name / Team	Primary Responsibility	Backup
DR Lead	IT & Cloud Operations Manager	Overall DR activation authority; coordinates all technical streams; declares recovery complete	CISO
Incident Commander	Mathias Benkert, SOC Lead	Leads active incident response; owns technical triage, containment, eradication; interfaces with DR Lead	Senior DevOps Engineer
AWS / Cloud Engineer	DevOps Team (3 engineers)	Executes cloud failover; IaC redeploy; RDS replica promotion; WAF and security group restoration	Managed Services on-call
Database Engineer	DevOps / DB Admin	Database backup validation, point-in-time restore, data integrity checks, replication re-sync	Senior DevOps Engineer
Security Engineer	SOC / Security Team	Confirms threat eradicated; restores SIEM, WAF, IDS/IPS; validates no persistent access before going live	SOC Lead
Network Engineer	IT & Cloud Ops	DNS failover, CDN reconfiguration, VPN verification, load balancer health checks	DevOps Team
Compliance Lead	Fraud Prevention & Compliance	PCI-DSS obligations during DR; validates no card data exposure; reconciles transaction metadata	Legal/Privacy Lead
Vendor Liaison	IT & Cloud Ops	AWS Support ticket escalation; payment gateway coordination; FedEx/UPS API restoration	CISO
Communications Lead	CISO	Status updates to executives, customers, and regulators during DR; approves all external messaging	Legal/Privacy Lead

5. Disaster Scenarios & Recovery Strategies

Scenarios are drawn directly from the ShopEase Risk Assessment, Threat Analysis, BIA, and the real Black Friday 2025 incident (IR-20251128-001). Each scenario maps to a specific recovery runbook in Section 7.

5.1 Scenario Matrix

Scenario	Likelihood	Impact	BIA Risk Rating	Primary Strategy	Runbook Ref
SQL Injection / Application Attack	Medium	High	CRITICAL	WAF containment + patch + DB restore	Runbook 7.1
DDoS Attack (Layer 3/7)	Medium	High	CRITICAL	AWS Shield + auto-scale + CDN failover	Runbook 7.2
AWS Region Failure	Low	High	HIGH	Multi-region failover via IaC + RDS replica promotion	Runbook 7.3
Payment Gateway Outage	Medium	High	HIGH	Secondary gateway activation + manual order queue reconciliation	Runbook 7.4
Ransomware / Malware Infection	Low-Med	High	HIGH	Isolate + wipe + full restore from clean backup	Runbook 7.5
Privileged Account Compromise / IAM Breach	Low	High	HIGH	Revoke + rotate + audit trail + rebuild IAM	Runbook 7.6
Database Corruption / Data Loss	Low-Med	High	HIGH	Point-in-time restore + integrity validation + reconciliation	Runbook 7.7
Backup Failure / Failed Restoration	Low-Med	High	HIGH	Validate backup integrity pre-incident; fallback to secondary region snapshot	Runbook 7.8
HQ / Physical Site Loss	Low	Medium	MEDIUM	Remote work activation + virtual EOC + warehouse as secondary site	BCP Section 7

6. Technical Architecture & DR Design

6.1 Production Architecture Summary

ShopEase operates a fully cloud-hosted environment on AWS. The following represents the primary production architecture that the DRP must restore:

Layer	Components	DR Dependency
Edge / CDN	AWS CloudFront, DNS Management, CDN	CloudFront failover routing to secondary region origin
Web / Application	AWS Frontend Server, AWS Load Balancer, EC2 Instances, WAF	IaC redeploy to secondary region; WAF rules restored from config repo
API Layer	Product Search API, AWS Backend Server, Fraud Scoring Engine, Payment Gateway Integration	API containers redeployed via IaC; payment gateway endpoint config updated
Data Layer	RDS Database, Encryption Key Management, Backup Systems	RDS cross-region read replica promoted to primary; point-in-time restore available
Security	IDS & IPS, Vulnerability Scanner, Cloud-native SIEM, Hardware Security Modules	Security stack must be restored BEFORE re-enabling public traffic
Monitoring	AWS Console, CloudWatch, SIEM dashboards	Monitoring validated active as first step in every runbook
Network	VPN, Cloud Firewalls, Cloud Routers, Access Points, VLAN	Security groups restored from IaC; VPN verified for DevOps access
Compliance Artifacts	PCI-DSS Artifacts, PCI-DSS compliance evidence	Artifacts stored in S3 with cross-region replication; never lost

6.2 DR Architecture Design

Active-Passive Multi-Region Configuration

- Primary region: us-east-1 (production). Secondary region: us-west-2 (DR standby)
- RDS read replica maintained in us-west-2 with continuous replication (lag target < 15 minutes to meet RPO)
- S3 cross-region replication active for all backup buckets, PCI artifacts, and compliance records
- CloudFront distribution pre-configured with secondary origin group pointing to us-west-2 load balancer
- Infrastructure-as-Code (Terraform/CDK) stored in version-controlled repository — full environment redeploy available in secondary region within 2-4 hours
- Daily automated backup snapshots replicated to secondary region; AWS Backup service manages retention

Recovery Point Design (Meeting RPO Targets)

Data Store	Replication Method	Target Lag	RPO Alignment
RDS (primary DB)	Cross-region read replica (async)	< 15 minutes	Meets 15-min RPO for Payment Processing; 30-min for E-Commerce
S3 (backups, artifacts)	S3 Cross-Region Replication	< 15 minutes	Meets all RPO targets for static assets and compliance artifacts
Application state (sessions)	Stateless architecture via JWT; no session state in DB	N/A — stateless	No data loss risk; tokens re-issued on restore
Inventory DB	Daily snapshot + manual count sheet during outage	Up to 4 hours (BIA-defined)	Meets Tier 2 RPO of 4 hours
SIEM logs / audit trail	CloudWatch Logs + S3 export; cross-region replication	Near real-time	Audit trail preserved even during primary region failure

6.3 Infrastructure-as-Code (IaC) DR Posture

- All AWS resources defined in Terraform/CDK with environment-specific variable files for primary and DR regions
- IaC repository: version-controlled (Git), access-controlled (DevOps team + read access for DR Lead)
- DR deployment validated quarterly in a test environment — not just documentation
- Key IaC modules: VPC + Security Groups, EC2 Auto Scaling Groups, RDS configuration, WAF rules, CloudFront distribution, IAM roles and policies
- Secrets management: AWS Secrets Manager + Hardware Security Modules; secrets are region-replicated

7. Recovery Runbooks

Each runbook follows the same structure: Trigger → Triage → Containment → Eradication → Recovery → Validation → Handoff. Times are targets against BIA RTOs. Log every action in the incident ticket.

Runbook 7.1 — SQL Injection / Application Attack Recovery

Applicable Scenario: Active or post-attack SQL injection (as occurred on Black Friday 2025, IR-20251128-001)

RTO Target: 4 hours (E-Commerce) | RPO: 30 minutes

Phase	Action	Owner	Target Time
1. DETECTION	Confirm via SIEM + CloudWatch: elevated DB CPU, anomalous query patterns, WAF alerts firing	SOC Lead	T+0 — T+10 min

Phase	Action	Owner	Target Time
1. DETECTION	Classify as SEV1 if checkout is impacted; notify DR Lead and BCP Coordinator	SOC Lead	T+10 min
2. CONTAINMENT	Tune WAF rules to block identified injection patterns (specific User-Agent, payload signatures)	Cloud Engineer	T+15 min
2. CONTAINMENT	Enable AWS WAF rate limiting on Product Search API endpoint; reduce max request rate	Cloud Engineer	T+15 min
2. CONTAINMENT	If DB transactions locked: restart RDS instance or force connection pool reset to clear locks	DB Engineer	T+20 min
3. ERADICATION	Identify exact vulnerability exploited (input field, API parameter); confirm using WAF + API logs	Security Engineer	T+30 min
3. ERADICATION	Deploy emergency patch to production API (do NOT wait for standard change cycle for SEV1)	Cloud/DevOps Engineer	T+60 min
3. ERADICATION	Verify patch eliminates vulnerability via controlled test payload (non-destructive probe in staging)	Security Engineer	T+75 min
4. RECOVERY	Verify DB integrity: check for injected data, unauthorized records, schema modifications	DB Engineer	T+90 min
4. RECOVERY	If data integrity confirmed clean: restore checkout and monitor via SIEM for 30-minute clean window	Cloud Engineer	T+120 min
4. RECOVERY	If data tampering detected: restore DB to pre-attack snapshot (point-in-time restore to T-30min)	DB Engineer	T+120-240 min
5. VALIDATION	Execute end-to-end checkout transaction test (test card in staging environment mirroring production)	DevOps Engineer	T+240 min
5. VALIDATION	Confirm WAF blocking rate returns to baseline; no injection attempts succeeding in logs	Security Engineer	T+240 min
6. HANDOFF	DR Lead confirms recovery complete; CISO approves All Clear; BCP deactivated	DR Lead + CISO	T+240 min

Runbook 7.2 — DDoS Attack Recovery

Applicable Scenario: Volumetric or application-layer DDoS causing website unavailability

RTO Target: 4 hours (E-Commerce) | RPO: 30 minutes (no data loss expected)

Phase	Action	Owner	Target Time
1. DETECTION	Confirm via CloudWatch: spike in request rate, bandwidth exhaustion, ALB 503/504 errors, SIEM volume anomaly	SOC Lead	T+0 — T+10 min
2. CONTAINMENT	Enable AWS Shield Advanced if not already active — contact AWS DDoS Response Team (DRT) via console	Cloud Engineer	T+10 min
2. CONTAINMENT	Enable CloudFront rate limiting; set WAF rule: block IPs with >500 requests/min to checkout endpoints	Cloud Engineer	T+15 min
2. CONTAINMENT	Scale out Auto Scaling Group: increase max capacity to absorb residual legitimate traffic	Cloud Engineer	T+20 min
2. CONTAINMENT	If attack volume exceeds mitigation: activate CloudFront geo-blocking for high-volume attack origin regions	Cloud Engineer	T+30 min
3. ERADICATION	Work with AWS DRT to identify attack signature and apply upstream scrubbing at AWS network edge	Cloud Engineer + AWS DRT	T+30 — T+120 min
4. RECOVERY	Confirm request rates normalizing; CloudWatch shows ALB response times returning to baseline	SOC Lead	T+120 min
4. RECOVERY	Gradually reduce geo-blocking; monitor for attack resumption	Cloud Engineer	T+150 min
5. VALIDATION	Run synthetic transaction test from external probe; confirm checkout functional end-to-end	DevOps Engineer	T+180 min
5. VALIDATION	30-minute clean monitoring window with SIEM; no anomalies	SOC Lead	T+210 min
6. HANDOFF	DR Lead confirms recovery; AWS Shield Advanced left enabled permanently for future protection	DR Lead	T+240 min

Runbook 7.3 — AWS Region Failure Recovery

Applicable Scenario: Primary AWS region (us-east-1) degraded or unavailable

RTO Target: 4 hours (E-Commerce) | RPO: 30 minutes (per RDS replica lag target)

Phase	Action	Owner	Target Time
1. DETECTION	Confirm AWS region failure via AWS Service Health Dashboard and CloudWatch cross-region alarms	SOC Lead	T+0 — T+15 min
2. CONTAINMENT	Activate BCP immediately — business processes shift to continuity mode	CISO / BCP Coordinator	T+15 min

Phase	Action	Owner	Target Time
3. RECOVERY	Promote RDS read replica in us-west-2 to primary (read-write): AWS Console > RDS > Promote Replica	DB Engineer	T+30 min
3. RECOVERY	Run IaC (Terraform/CDK) to deploy application stack to us-west-2: EC2, Load Balancer, WAF, Security Groups	Cloud Engineer	T+45 min
3. RECOVERY	Deploy application containers / AMIs to new EC2 instances in us-west-2 Auto Scaling Group	Cloud Engineer	T+90 min
3. RECOVERY	Update CloudFront distribution: switch origin to us-west-2 ALB DNS endpoint	Cloud Engineer	T+120 min
3. RECOVERY	Update Route 53 DNS records to point to us-west-2 CloudFront/ALB endpoint (TTL: 60s)	Network Engineer	T+125 min
3. RECOVERY	Restore WAF rules from config repository to us-west-2 WAF instance	Security Engineer	T+130 min
3. RECOVERY	Restore SIEM configuration in us-west-2; verify log ingestion from all new EC2 instances	Security Engineer	T+150 min
3. RECOVERY	Update payment gateway API endpoint configuration (if regional endpoint required)	Cloud Engineer	T+160 min
4. VALIDATION	End-to-end checkout test in secondary region; verify all APIs responding	DevOps Engineer	T+200 min
4. VALIDATION	Verify SIEM alerts active; security monitoring live in secondary region	Security Engineer	T+210 min
4. VALIDATION	Confirm DB replication lag is < 15 minutes before lifting BCP manual order queue mode	DB Engineer	T+215 min
5. HANDOFF	DR Lead declares recovery in secondary region complete; DR Lead issues All Clear to CISO	DR Lead	T+240 min

Runbook 7.4 — Payment Gateway Outage Recovery

Applicable Scenario: Third-party PCI payment gateway unavailable for > 30 minutes

RTO Target: 2 hours | RPO: 15 minutes

CRITICAL: This runbook requires a secondary PCI-compliant payment gateway to be pre-contracted and pre-integrated. This is a known gap — see Section 10 Improvement Actions. Until resolved, manual order queue (BCP Runbook B-1) is the only fallback.

Phase	Action	Owner	Target Time
1. DETECTION	Confirm gateway outage via vendor status page, API health check endpoint,	SOC Lead / Fraud Lead	T+0 — T+15 min

Phase	Action	Owner	Target Time
	and CloudWatch payment error rate alarms		
2. CONTAINMENT	Activate BCP Runbook B-1: enable manual order capture queue; notify Customer Support to accept phone/email orders	BCP Coordinator	T+15 min
2. CONTAINMENT	Contact gateway vendor NOC hotline; obtain ETA for restoration; escalate to account manager	Vendor Liaison	T+15 min
3. RECOVERY (Option A: Secondary Gateway)	Retrieve secondary gateway credentials from HSM (requires 2-person authentication)	Fraud Lead + DevOps	T+30 min
3. RECOVERY (Option A)	Update payment API config in AWS Secrets Manager to secondary gateway endpoint	Cloud Engineer	T+45 min
3. RECOVERY (Option A)	Run test transaction through secondary gateway; confirm PCI tokenization working correctly	Fraud Lead	T+60 min
3. RECOVERY (Option A)	Enable secondary gateway for live traffic; notify Support team to direct customers to checkout	Cloud Engineer	T+75 min
3. RECOVERY (Option B: Manual Queue)	If no secondary gateway: log all orders via encrypted manual form (BCP form D-1) with payment deferred	Support Team	T+15 min ongoing
4. VALIDATION	Process 5 test transactions via active gateway; confirm in gateway dashboard and internal DB	Fraud Lead	T+90 min
4. VALIDATION	Reconcile any manual order queue entries against gateway records	Finance Lead	T+120 min
5. HANDOFF	DR Lead confirms payment processing restored; CISO approves All Clear	DR Lead	T+120 min

Runbook 7.5 — Ransomware / Malware Recovery

Applicable Scenario: Confirmed ransomware or destructive malware on AWS-hosted systems or endpoints

RTO Target: Variable — up to 24 hours for full rebuild | RPO: Last clean backup (daily minimum)

Phase	Action	Owner	Target Time
1. DETECTION	Confirm via SIEM + endpoint EDR: encryption activity, mass file modification, ransom note, C2 beaconing	SOC Lead	T+0 — T+20 min

Phase	Action	Owner	Target Time
2. CONTAINMENT	IMMEDIATE: Isolate affected EC2 instances — modify Security Group to deny ALL inbound/outbound traffic	Cloud Engineer	T+20 min
2. CONTAINMENT	Revoke all IAM roles and access keys associated with affected instances	Cloud Engineer	T+25 min
2. CONTAINMENT	Terminate affected VPN sessions; force MFA re-auth for all DevOps users	Security Engineer	T+25 min
2. CONTAINMENT	Snapshot all affected EBS volumes BEFORE any modification (preserve forensic evidence)	Cloud Engineer	T+30 min
3. ERADICATION	Identify malware entry vector via CloudTrail, SIEM, and VPC flow logs	Security Engineer	T+60 min
3. ERADICATION	Engage AWS Security or third-party IR firm if lateral movement suspected	DR Lead / CISO	T+60 min
3. ERADICATION	Do NOT attempt to decrypt/negotiate — rebuild from clean backup is always the recovery path	DR Lead	Policy
4. RECOVERY	Identify last known clean backup (pre-infection RDS snapshot + S3 backup)	DB Engineer	T+90 min
4. RECOVERY	Deploy fresh EC2 instances from AWS AMI (never reuse compromised instances)	Cloud Engineer	T+120 min
4. RECOVERY	Restore RDS from clean snapshot; validate data integrity before connecting to application	DB Engineer	T+180 min
4. RECOVERY	Restore application from IaC and verified clean artifact repository	Cloud Engineer	T+300 min
5. VALIDATION	Full security scan of restored environment before re-enabling public access	Security Engineer	T+360 min
5. VALIDATION	SIEM and EDR active and monitoring all restored systems for 2 hours before go-live	SOC Lead	T+420 min
6. HANDOFF	DR Lead + Security Engineer co-sign restoration complete; CISO approves re-enabling public traffic	DR Lead + CISO	T+480 min max

Runbook 7.6 — Privileged Account Compromise / IAM Breach

Applicable Scenario: DevOps credentials compromised; IAM role privilege escalation; unauthorized AWS console access

RTO Target: 2 hours (security controls restored) | RPO: N/A — no data expected lost

Phase	Action	Owner	Target Time
1. DETECTION	SIEM alert: unusual IAM API calls (CreateUser, AttachUserPolicy, ConsoleLogin from unknown IP/geo)	SOC Lead	T+0 — T+15 min
2. CONTAINMENT	Immediately disable compromised IAM user/role via AWS Console or CLI	Cloud Engineer	T+15 min
2. CONTAINMENT	Revoke all active sessions: aws sts get-caller-identity → invalidate all session tokens	Cloud Engineer	T+15 min
2. CONTAINMENT	Require MFA re-authentication for ALL privileged accounts — no exceptions	Security Engineer	T+20 min
2. CONTAINMENT	Enable AWS CloudTrail enhanced logging; capture all API calls made by compromised identity	Security Engineer	T+20 min
3. ERADICATION	Audit all resources touched by compromised identity: EC2, S3, RDS, IAM, Secrets Manager	Cloud Engineer	T+60 min
3. ERADICATION	Rotate ALL access keys and secrets — assume all were potentially exposed	Cloud Engineer	T+60 min
3. ERADICATION	Review and tighten IAM policies: enforce least privilege; remove wildcard permissions	Security Engineer	T+90 min
4. RECOVERY	Redeploy IAM roles and policies from IaC repository to ensure clean state	Cloud Engineer	T+90 min
4. RECOVERY	Enable AWS GuardDuty anomaly detection if not already active	Security Engineer	T+100 min
5. VALIDATION	Review CloudTrail for 72 hours prior to confirm full blast radius of compromise	Security Engineer	T+120 min
5. VALIDATION	Verify no new unauthorized IAM entities were created; check all trust relationships	Cloud Engineer	T+120 min
6. HANDOFF	DR Lead confirms IAM integrity restored; Security Engineer co-signs; notify CISO	DR Lead + Security	T+120 min

Runbook 7.7 — Database Corruption / Data Loss Recovery

Applicable Scenario: RDS data corruption, accidental deletion, or data integrity failure confirmed
RTO Target: 4 hours | RPO: 30 minutes (point-in-time restore target)

Phase	Action	Owner	Target Time
1. DETECTION	Confirm corruption via application errors, DB query failures, data consistency checks, or integrity alerts	SOC Lead / DB Engineer	T+0 — T+20 min

Phase	Action	Owner	Target Time
2. CONTAINMENT	Take immediate manual RDS snapshot BEFORE any restore attempt (preserve current state for forensics)	DB Engineer	T+20 min
2. CONTAINMENT	Set RDS to read-only mode or suspend writes to prevent further corruption propagation	DB Engineer	T+25 min
3. RECOVERY	Identify the corruption timestamp using CloudWatch metrics and application logs	DB Engineer	T+40 min
3. RECOVERY	Initiate RDS point-in-time restore to T-30min (or earliest clean state): AWS Console > RDS > Restore to Point in Time	DB Engineer	T+50 min
3. RECOVERY	Restore to a new RDS instance (do not overwrite existing — maintain forensic copy)	DB Engineer	T+90 min
3. RECOVERY	Run data integrity validation queries on restored instance before connecting to application	DB Engineer	T+150 min
4. RECOVERY	Update application DB connection string to point to restored instance	Cloud Engineer	T+160 min
4. RECOVERY	Reconcile any transactions processed after RPO cutoff using manual order queue or payment gateway logs	Finance / Fraud Lead	T+180 min
5. VALIDATION	Run full data integrity test suite against restored database	DB Engineer	T+200 min
5. VALIDATION	Confirm no PCI metadata exposure from corruption event; notify Compliance Lead if uncertain	Fraud Lead	T+210 min
6. HANDOFF	DB Engineer and DR Lead co-sign data integrity confirmed; CISO approves All Clear	DR Lead + DB Engineer	T+240 min

Runbook 7.8 — Backup Failure / Failed Restoration

Applicable Scenario: Scheduled backup failed silently; backup restoration fails during DR event

Priority: CRITICAL — a failed backup during active DR has no easy fix. Prevention is the primary control.

Phase	Action	Owner	Target Time
PREVENTION	Weekly automated backup validation job: restore latest snapshot to isolated test RDS instance; run integrity check; auto-alert on failure	DevOps / SOC	Weekly (automated)

Phase	Action	Owner	Target Time
PREVENTION	Monthly manual restoration drill: DevOps engineer performs full restore and documents time-to-restore	DevOps Lead	Monthly
1. DETECTION	During DR: backup restore fails — error returned by AWS Backup or RDS snapshot restore job	DB Engineer	T+0
2. CONTAINMENT	Do not delete any existing backup — preserve all available restore points	DB Engineer	T+5 min
2. CONTAINMENT	Check S3 cross-region replication bucket for available backup copies in us-west-2	Cloud Engineer	T+10 min
3. RECOVERY (Option A)	Attempt restore from secondary region S3 backup copy	DB Engineer	T+20 min
3. RECOVERY (Option B)	If all RDS snapshots corrupted: rebuild DB schema from IaC; restore from last valid transaction log export	DB Engineer + Cloud	T+60 min
3. RECOVERY (Option C)	Contact AWS Premium Support: request assistance with snapshot corruption recovery	Vendor Liaison	T+30 min (parallel)
4. VALIDATION	Validate restored DB contains expected data volume and schema integrity before connecting app	DB Engineer	Post-restore
5. POST-INCIDENT	Root cause analysis on backup failure mandatory; backup strategy reviewed and updated within 30 days	DR Lead	T+5 business days

8. Data Recovery & Integrity Validation

8.1 Recovery Priority Sequence

The following sequence must be followed for all DR events involving data recovery. Do not skip or reorder steps:

- 1. Preserve forensic copy of corrupted/affected state (snapshot) before ANY recovery action
- 2. Identify clean restore point — confirm timestamp in CloudTrail and SIEM logs
- 3. Restore to isolated environment first — NEVER directly overwrite production
- 4. Run data integrity validation suite on isolated restore (see 8.2)
- 5. Confirm PCI compliance: no card data outside HSM; transaction metadata scope identified
- 6. Reconcile any data generated between RPO cutoff and restoration (manual queue, payment logs)
- 7. Only after validation complete: promote restored DB to production and reconnect application

8.2 Data Integrity Validation Checklist

Check	Method	Pass Criteria	Owner
Record count validation	Query: SELECT COUNT(*) on critical tables vs. expected baseline	Within 0.1% of pre-incident count	DB Engineer
Schema integrity	Compare live schema to IaC-defined schema definition (schema drift check)	Zero unauthorized schema changes	DB Engineer
Transaction reconciliation	Cross-reference payment gateway transaction IDs with internal order DB records	100% of gateway transactions present in DB	Finance / Fraud Lead
PCI metadata scope	Verify no card PAN, CVV, or authentication data present in any DB table	Zero prohibited data fields populated	Fraud / Compliance Lead
Referential integrity	Run foreign key constraint validation across Orders, Customers, Inventory tables	Zero constraint violations	DB Engineer
Backup hash validation	Compare SHA-256 hash of restored snapshot to pre-stored hash from backup manifest	Hashes match exactly	DevOps Engineer
SIEM audit trail continuity	Verify CloudTrail logs present for the DR window; no logging gaps	Continuous audit trail with no gaps > 5 minutes	SOC Lead

8.3 Post-Recovery Reconciliation Process

- Finance/Fraud team reconciles manual order queue (BCP Appendix D-1 forms) against restored DB within 24 hours of recovery
- Any transaction processed between RPO cutoff and full DB restoration must be manually entered by Finance Lead
- Inventory team reconciles manual stock count sheets against restored DB snapshot — delta < 2% considered acceptable
- Customer Support imports all continuity ticket log entries into restored CRM within 24 hours
- Reconciliation completion signed off by Finance Lead and DR Lead; documented in incident ticket

9. DR Testing, Validation & Exercises

Test Type	Frequency	Scope	Owner	Success Criteria	Last Tested
Backup Restoration Test	Monthly (automated) + Quarterly (manual)	Restore latest RDS snapshot to isolated instance; run integrity checks	DevOps Lead	Restore completes within 2 hours; integrity checks pass 100%	TBD — schedule immediately
Secondary Region Failover Test	Semi-annual (off-peak window)	Full IaC redeploy to us-west-2; RDS replica promotion; CloudFront failover; end-to-end transaction test	Cloud Engineer + DR Lead	E-Commerce functional in secondary region within 4-hour RTO	TBD
WAF & DDoS Mitigation Test	Annual	Controlled load test with simulated attack signatures in staging; validate WAF blocking rate	Security Engineer	Known attack signatures blocked 100%; legitimate traffic passes	TBD
Secondary Payment Gateway Test	Annual (after gateway contracted)	Full transaction cycle through secondary gateway in test mode; tokenization and PCI compliance validated	Fraud Lead + Cloud Engineer	Test transactions processed < 30 min; PCI tokenization confirmed	N/A — gateway not yet contracted
Ransomware Recovery Simulation	Annual tabletop + bi-annual partial drill	Tabletop: team walks through Runbook 7.5 step-by-step; Drill: isolate test instance, restore from backup	DR Lead + Security Engineer	Team completes runbook with no critical errors; RTO within 24 hours	TBD
IAM Compromise Drill	Annual	Simulate compromised IAM credential: revoke, audit, rotate, redeploy — using non-production IAM role	Security Engineer	IAM integrity restored within 2-hour RTO; CloudTrail confirms full blast radius identified	TBD
Full DR Activation Simulation	Annual	Unannounced full DR scenario — all teams activate runbooks simultaneously; timed against RTOs	CISO + DR Lead	All Tier 1 systems recovered within respective RTOs; no	TBD

Test Type	Frequency	Scope	Owner	Success Criteria	Last Tested
				critical runbook failures	

9.1 Post-Test Requirements

- Every test generates a Test Report: scenario, actions taken, time-against-RTO, issues found, pass/fail verdict
- Any RTO breach during testing is classified as a Critical Finding — must be remediated within 30 days
- Test reports stored in secure document management system; reviewed annually by CISO
- Lessons Learned fed back into runbook updates and BIA refresh

10. Known Gaps & Improvement Actions

The following gaps were identified from the Risk Assessment, BIA, Threat Analysis, and the Black Friday 2025 incident (IR-20251128-001). All are tracked with owners and target dates. Critical gaps MUST be resolved before peak season (Q4 2026).

Source	Gap	Recommended Action	Priority	Owner	Target
IR-20251128-001 (Black Friday)	Known vulnerability not patched from staging to production — root cause of \$95k incident	Implement DevSecOps pipeline: automated patch deployment parity between staging and prod; block prod deploy if critical CVEs unpatched in staging	CRITICAL	DevOps Lead	Q2 2026
Risk Assessment + BIA	Single payment gateway — no contracted failover (Runbook 7.4 partial only)	Contract and pre-integrate a secondary PCI-compliant payment gateway; test annually	CRITICAL	Finance / Vendor Mgr	Q2 2026
Risk Assessment	Backup restoration untested — no validation that backups are restorable	Implement monthly automated backup validation job; quarterly full manual restore drill; document RTA (Recovery Time Actual)	CRITICAL	DevOps Lead	Q2 2026
Risk Assessment	Insufficient DDoS protection — no AWS Shield Advanced; limited WAF rate limiting	Enable AWS Shield Advanced; configure CloudFront rate limiting; define and test auto-scaling triggers for Black Friday peak load	HIGH	IT/Cloud Lead	Q2 2026
Risk Assessment	Incomplete SIEM alert coverage —	Conduct SIEM rule review; add detection	HIGH	SOC Lead	Q2 2026

Source	Gap	Recommended Action	Priority	Owner	Target
BIA / Risk Assessment	DB query anomalies and API abuse not alerted	rules for: high-volume DB queries, WAF bypass attempts, IAM anomalies, API rate spikes	HIGH	DevOps Lead	Q3 2026
	IaC never tested for secondary region redeploy — untested runbook = untested recovery	Execute secondary region failover test in off-peak maintenance window; document actual recovery time vs. RTO			
Risk Assessment	Overprivileged IAM roles — DevOps has full AWS admin; no least-privilege enforcement	IAM policy review and tightening; implement AWS IAM Access Analyzer; enforce MFA for all console access including federated roles	HIGH	Security Engineer	Q2 2026
Risk Assessment	No secondary shipping carrier integration — single FedEx/UPS dependency	Pre-integrate USPS or DHL as backup carrier API; test label generation via fallback carrier quarterly	MEDIUM	Vendor Manager	Q3 2026
Threat Analysis	No bot/credential stuffing protection on customer login and checkout endpoints	Implement AWS WAF Bot Control or equivalent; enable CAPTCHA on checkout and account recovery flows	MEDIUM	Security Engineer	Q3 2026

11. Communications During DR

The DR communications plan supplements the BCP communications plan (BCP Section 9). During active DR, the following additional protocols apply:

Audience	Trigger	Message Content	Channel	Frequency	Owner
DR Team (internal)	DR activation	Active runbook ID, current phase, ETA, blockers	EOC video bridge + Slack/Teams	Every 30 minutes	DR Lead
CISO / Executives	DR activation + every major milestone	Business impact status, ETA to resolution, resource needs	Direct call + email	Hourly	DR Lead
BCP Coordinator	Phase changes in DRP	Technical status, readiness for BCP-to-DRP	EOC bridge	At phase transitions	DR Lead

Audience	Trigger	Message Content	Channel	Frequency	Owner
AWS Support / Vendors	If vendor issue involved	handoff or DRP-to-normal handoff Incident ticket number, symptoms, impact, escalation request	Vendor support portal + phone	Every 2 hours + at escalation	Vendor Liaison
Legal / Compliance	If data exposure confirmed or suspected	Nature of potential exposure, scope estimate, timeline of events	Secure email + direct call	Immediately on discovery + daily	DR Lead + CISO
Customers (via BCP)	Extended outage > 2 hours	Service impact and ETA (generic; no technical details)	Website banner + email	Every 2 hours via BCP Coordinator	CISO / Marketing

12. Governance & Continuous Improvement

12.1 DRP Review Triggers

- Annual mandatory review aligned with BIA and BCP refresh cycle
- After any real DR activation — post-incident review within 5 business days; DRP updated within 30 days
- After any major infrastructure change: new AWS regions, new services, application architecture changes
- After any significant vendor change: new payment gateway, new cloud provider, shipping partner changes
- After any DR test that reveals a Critical finding (RTO breach, runbook failure, data integrity failure)
- After any regulatory change affecting PCI-DSS obligations, state breach law requirements, or cloud compliance

12.2 Metrics & KPIs

Metric	Target	Measurement Method	Review Cadence
RTO Achievement Rate	100% of Tier 1 systems meet RTO in tests	Time recorded from DR activation to system validation	Per test + annually
RPO Achievement Rate	Zero data loss beyond RPO thresholds	Data gap analysis post-restore (record count + timestamp delta)	Per test + after any activation
Backup Success Rate	> 99.5% of scheduled backups succeed	AWS Backup + CloudWatch automated monitoring	Weekly automated alert

Metric	Target	Measurement Method	Review Cadence
Mean Time to Detect (MTTD)	< 10 minutes for Tier 1 system failure	SIEM alert timestamp vs. confirmed incident timestamp	Per incident
Mean Time to Recover (MTTR)	< 4 hours for Tier 1 (per RTO)	DR activation timestamp vs. All Clear timestamp	Per incident / test
Open Critical Findings	Zero open Critical findings > 30 days	Improvement action tracker (Section 10)	Monthly review by CISO
DR Test Coverage	All runbooks tested at least annually	Test schedule completion tracking	Annually

13. Appendices

Appendix A — DR Contact List

Role	Name	Primary Contact	Alt Contact	Availability
DR Lead	IT & Cloud Ops Manager	[REDACTED]	[REDACTED]	24x7 on-call
Incident Commander / SOC	Mathias Benkert	[REDACTED]	[REDACTED]	24x7 on-call
Cloud / DevOps Engineer	DevOps Team (3 engineers)	[REDACTED]	On-call rotation	24x7 rotation
DB Engineer	DB Admin / DevOps	[REDACTED]	[REDACTED]	24x7 on-call
Security Engineer	SOC / Security Team	[REDACTED]	[REDACTED]	Business hours + on-call
CISO / Exec Sponsor	Christian Acevedo	[REDACTED]	[REDACTED]	24x7
Legal / Privacy Lead	TBD	[REDACTED]	[REDACTED]	Business hours + emergency
Fraud / Compliance Lead	Fraud Prevention Team	[REDACTED]	[REDACTED]	Business hours + peak season on-call
AWS Support	AWS TAM / Business Support	AWS Console	Business Support phone	24x7
Payment Gateway NOC	Vendor Contact (TBD)	[REDACTED]	[REDACTED]	24x7 for SEV1
FedEx API Support	Integration Team	[REDACTED]	[REDACTED]	Business hours

Appendix B — AWS Architecture DR Quick Reference

Primary Region: us-east-1 (N. Virginia) | DR Region: us-west-2 (Oregon)

Resource	Primary (us-east-1)	DR Standby (us-west-2)	Failover Method
EC2 / Application Servers	Auto Scaling Group — active	IaC redeploy on activation	Terraform/CDK apply to us-west-2
RDS Database	Primary read-write instance	Cross-region read replica	Promote replica to primary (RDS Console)
S3 Buckets	Primary buckets	CRR replicas (real-time)	Update application config to us-west-2 bucket endpoints
CloudFront CDN	Origin: us-east-1 ALB	Origin group: us-west-2 ALB	CloudFront origin failover (automatic)
WAF	us-east-1 WAF web ACL	Deploy from rules config repo	IaC deploy WAF rules to us-west-2
Route 53 DNS	A record → us-east-1 CloudFront	Update A record to us-west-2 CloudFront	Route 53 record update (TTL 60s)
Secrets Manager	Primary secrets	Cross-region replication	Update app config to us-west-2 secrets ARNs
AWS Backup	Backup jobs in us-east-1	Cross-region copy to us-west-2	Restore from us-west-2 copy
CloudWatch / SIEM	Primary monitoring	Redeploy SIEM config from repo	IaC redeploy; update log group ARNs

Appendix C — IaC Deployment Commands (Reference)

The following commands represent the DR deployment workflow. Actual commands depend on finalized IaC toolchain and environment variable configuration. DevOps team to maintain current, tested versions in the DR runbook repository.

```
# Step 1: Configure AWS CLI for DR region
export AWS_DEFAULT_REGION=us-west-2

# Step 2: Initialize and apply Terraform for DR environment
cd /infra/terraform/dr-environment
terraform init -backend-config=dr-backend.tfvars
terraform plan -var-file=dr.tfvars -out=dr-plan.tfplan
terraform apply dr-plan.tfplan

# Step 3: Promote RDS Read Replica (AWS CLI)
aws rds promote-read-replica --db-instance-identifier shopease-db-dr-replica --region us-west-2

# Step 4: Update CloudFront origin to DR ALB
aws cloudfront update-distribution --id <CF_DIST_ID> --if-match <ETAG> --distribution-config file:///dr-cloudfront-config.json
```

```
# Step 5: Validate deployment
curl -I https://shopease.com/health # Expect 200 OK from DR region
```

Appendix D — DR Activation Decision Tree

Use this tree at incident declaration to determine which runbook(s) to activate. Multiple runbooks may activate simultaneously for complex incidents.

Question	Yes → Action	No → Next Question
Is the E-Commerce checkout unavailable?	Activate Runbook 7.1 (SQL Injection) OR 7.2 (DDoS) — determine which via SIEM	Proceed to Q2
Is the cause a DDoS / traffic spike?	Activate Runbook 7.2 (DDoS)	Proceed to Q3
Is the AWS primary region unavailable?	Activate Runbook 7.3 (Region Failure)	Proceed to Q4
Is the payment gateway down?	Activate Runbook 7.4 (Payment Gateway)	Proceed to Q5
Is malware / ransomware suspected?	Activate Runbook 7.5 (Ransomware) — ISOLATE FIRST	Proceed to Q6
Are IAM credentials or admin access compromised?	Activate Runbook 7.6 (IAM Breach) — REVOKE FIRST	Proceed to Q7
Is there data corruption or unexpected data loss?	Activate Runbook 7.7 (DB Corruption)	Proceed to Q8
Did backup restoration fail during another DR event?	Activate Runbook 7.8 (Backup Failure)	Escalate to DR Lead for triage of novel scenario

Appendix E — Regulatory & Compliance Obligations During DR

Regulation	Trigger	Timeline	Action Required	Owner
PCI-DSS	Confirmed or suspected exposure of payment transaction metadata or cardholder data	Immediate — notify acquirer and card brands promptly	File PCI-DSS incident report; engage QSA if card data exposure possible; preserve all logs	Fraud Lead + Legal
Florida DBPA (Fla. Stat. 501.171)	Breach of Florida resident PII (name + financial data)	Within 30 days of determination	Notify affected individuals; notify FL AG if > 500 records	Legal/Privacy Lead
GDPR (if applicable)	EU customer PII exposed	Within 72 hours of awareness	Notify relevant EU supervisory authority	Legal/Privacy Lead

Regulation	Trigger	Timeline	Action Required	Owner
PCI-DSS Section 12.10	Any security incident affecting cardholder data environment	Immediate activation of incident response plan	Preserve evidence, document timeline, engage forensics if needed	SOC Lead + Fraud Lead
AWS Shared Responsibility	Misconfiguration or vulnerability in customer-managed AWS resources	Per AWS SLA and support agreement	File AWS Support case; engage AWS DRT for DDoS (Runbook 7.2); document all remediation steps	Cloud Engineer + DR Lead

— END OF DOCUMENT —